HACKCHAIN SECURITY REVIEW

Smart Contract Audit Report / Informe de Auditoría de Smart Contracts

Final bilingual client report - Foundry-only reproducibility

Auditor / Auditor:
Julian Ruiz
Blockchain Engineer - Smart Contract Security Reviewer
linkedin.com/in/julian-ruiz-v

Document / Documento:
Executive Audit Report / Informe Ejecutivo
Audited commit / Commit auditado:
290377e9862aeabaa2814bcd0bac9ddad2707ce8
Date / Fecha:
11 July 2026 / 11 de julio de 2026

Executive summary / Resumen ejecutivo

ES

Conclusión

El conjunto auditado no debe desplegarse con fondos reales hasta corregir todos los hallazgos High y Medium, implementar los controles de emergencia y repetir la suite completa de seguridad.

EN

Conclusion

The audited system should not be deployed with real funds until every High and Medium finding is remediated, emergency controls are implemented, and the complete security suite is rerun.

5	6	6	7
HIGH / ALTA	MEDIUM / MEDIA	LOW / BAJA	INFORMATIONAL

Foundry validation evidence / Evidencia de validación Foundry

The delivered evidence file records 17 passing Foundry tests: 10 security PoCs, 6 business-logic PoCs, and 1 fuzz/invariant suite. All reproduction commands in this report are native Foundry commands and correspond to the delivered Foundry repository.

```
forge build
forge test -vv
forge test --match-path "test/security/*.t.sol" -vvvv
forge test --match-path "test/business/*.t.sol" -vvvv
forge test --match-path "test/invariant/*.t.sol" -vvvv
forge fmt --check
forge test --gas-report
```

Scope / Alcance

Item	Audited value / Valor auditado
Repository model / Modelo	Foundry-only
Audited commit / Commit	290377e9862aeabaa2814bcd0bac9ddad2707ce8
Contracts / Contratos	11 Solidity source contracts under src/
Solidity	0.8.24
EVM target	Cancun
OpenZeppelin	5.0.2 vendored under lib/
Evidence	audit/evidence/forge-build.txt and forge-test.txt

Methodology / Metodología

ES

- Revisión manual de control de acceso, custodia, contabilidad y llamadas externas.
- Trazado de reglas de negocio contra los mecanismos del token HACK.
- PoC unitarias, fuzz y comprobaciones invariantes en Foundry.
- Análisis de pausa, solvencia, idempotencia y dependencias privilegiadas.

EN

- Manual review of access control, custody, accounting, and external calls.
- Business-rule tracing against documented HACK token mechanisms.
- Foundry unit PoCs, fuzz tests, and invariant checks.
- Pause, solvency, idempotency, and privileged-dependency analysis.

Finding register / Registro de hallazgos

ID	Severity	Finding / Hallazgo	Contracts
H-01	**High / Alta**	La recompensa de referidos puede cobrarse inmediatamente y permite drenaje mediante identidades Sybil Referral rewards are immediately claimable and Sybil wallets can drain the pool	ReferralSystem.sol, StakingContract.sol
H-02	**High / Alta**	La retirada del principal depende del pago de la recompensa y puede quedar bloqueada Principal withdrawal depends on reward payment and can be blocked	StakingContract.sol, IncentivesPool.sol
H-03	**High / Alta**	Las vistas académicas pueden inflarse sin límite para apropiarse del pool de educadores Academic views can be inflated without limit to capture the educator pool	MembershipSystem.sol
H-04	**High / Alta**	Las penalizaciones son voluntarias porque dependen de la aprobación del infractor Penalties are voluntary because they depend on the offender's allowance	PenaltySystem.sol, HackTokenERC20.sol

ID	Severity	Finding / Hallazgo	Contracts
H-05	**High / Alta**	La base de penalización usa saldo movible y la venta masiva se evalúa contra el balance posterior Penalty calculations use movable balances and mass-sale checks use post-sale state	PenaltySystem.sol, StakingContract.sol
M-01	**Medium / Media**	`deposit()` incrementa la contabilidad del pool sin comprobar una transferencia real deposit() increases pool accounting without proving a token transfer	IncentivesPool.sol
M-02	**Medium / Media**	La exención de comisión se activa inmediatamente y puede permanecer con elegibilidad obsoleta Fee exemption activates immediately and can remain stale	StakingContract.sol
M-03	**Medium / Media**	El ganador de reputación pierde una ventana de reclamación todavía vigente al cambiar de época A reputation winner can lose a still-open claim window at an epoch boundary	ReputationBunises.sol
M-04	**Medium / Media**	Varios eventos off-chain carecen de identificadores únicos e idempotencia Off-chain events lack unique identifiers and idempotency	EventRewards.sol, EducatorBonuses.sol, RecruiterBonuses.sol
M-05	**Medium / Media**	Transferir `Ownable` no transfiere la administración de `AccessControl` Transferring Ownable ownership does not migrate AccessControl administration	HackTokenERC20.sol
M-06	**Medium / Media**	Los bonos de recruiter no verifican actividad real ni consistencia de registro/KYC Recruiter rewards do not prove real activity or registration/KYC consistency	RecruiterBonuses.sol
L-01	**Low / Baja**	Se ignoran valores de retorno de transferencias ERC20 en membresías y penalizaciones ERC-20 transfer return values are ignored in memberships and penalties	MembershipSystem.sol, PenaltySystem.sol

ID	Severity	Finding / Hallazgo	Contracts
L-02	**Low / Baja**	La validación de índice de stake ocurre después de acceder al array Stake index validation occurs after the array is accessed	StakingContract.sol
L-03	**Low / Baja**	El estado de membresía avanzada permanece activo tras expirar y permite penalizar cancelaciones vencidas Expired advanced memberships remain flagged active and can be charged a cancellation penalty	MembershipSystem.sol
L-04	**Low / Baja**	Bucles y lotes no acotados pueden exceder el límite de gas Unbounded loops and batches can exceed the block gas limit	StakingContract.sol, TalentBonuses.sol
L-05	**Low / Baja**	El patrocinador de un proyecto puede sobrescribirse y no existe ruta de reembolso Project sponsor attribution can be overwritten and funds have no refund path	TalentBonuses.sol
L-06	**Low / Baja**	La pausa de emergencia no es granular y puede bloquear retiros Emergency pausing is not granular and can block withdrawals	HackTokenERC20.sol, StakingContract.sol, MembershipSystem.sol, IncentivesPool.sol
I-01	**Informational / Informativa**	“Mes” se implementa como épocas globales de 30 días y puede borrar calificaciones al cambio Thirty-day global epochs do not match calendar months and can erase earned progress	ReferralSystem.sol, EventRewards.sol, RecruiterBonuses.sol, TalentBonuses.sol, ReputationBunises.sol
I-02	**Informational / Informativa**	Las recompensas asignadas no están reservadas y dependen de liquidez/roles en el momento del claim Eligible rewards are not reserved and remain dependent on pool liquidity and roles	Todos los módulos de recompensas, IncentivesPool.sol

ID	Severity	Finding / Hallazgo	Contracts
I-03	**Informational / Informativa**	Faltan bloqueo de dependencias, pruebas originales, scripts de despliegue y configuración de roles The production repository must retain the reproducible Foundry environment and role configuration	Repositorio completo
I-04	**Informational / Informativa**	Problemas de calidad y observabilidad reducen mantenibilidad Code quality and observability issues reduce maintainability	ReputationBunises.sol, MembershipSystem.sol, PenaltySystem.sol, varios
I-05	**Informational / Informativa**	Mappings públicos y getters explícitos duplican la superficie ABI Public mappings and explicit getters duplicate the ABI surface	EducatorBonuses.sol, EventRewards.sol, PenaltySystem.sol, RecruiterBonuses.sol, ReferralSystem.sol, StakingContract.sol, TalentBonuses.sol
I-06	**Informational / Informativa**	NatSpec incompleto y parcialmente desalineado con la lógica NatSpec is incomplete and partially inconsistent with behavior	Todos los contratos e interfaces
I-07	**Informational / Informativa**	Modernización condicional a ReentrancyGuardTransient Conditional modernization to ReentrancyGuardTransient	EducatorBonuses.sol, EventRewards.sol, MembershipSystem.sol, PenaltySystem.sol, RecruiterBonuses.sol, ReferralSystem.sol, ReputationBunises.sol, StakingContract.sol, TalentBonuses.sol

H-01 La recompensa de referidos puede cobrarse inmediatamente y permite drenaje mediante identidades Sybil

High / Alta

Referral rewards are immediately claimable and Sybil wallets can drain the pool

CONTRACTS / CONTRATOS
ReferralSystem.sol, StakingContract.sol

LINES / LÍNEAS
ReferralSystem.sol:93-149; StakingContract.sol:105-130; StakingContract.sol:221-222

ES
Descripción e impacto

`validateReferral()` solo consulta el total actualmente depositado mediante `getTotalStaked()`. No verifica que el stake tenga duración de un mes, que haya permanecido bloqueado durante un mes, que el referido haya sido registrado antes de hacer stake ni que referrer y referred correspondan a identidades distintas. Un usuario puede controlar ambas wallets, depositar 1.000 HACK y validar de inmediato. Un atacante puede crear pares de wallets, obtener 1.000 HACK por cada referido inmediatamente y repetir el proceso con múltiples referrers para eludir el límite mensual por dirección. El capital queda bloqueado temporalmente, pero la recompensa se recibe en el acto y el pool puede drenarse económicamente.

EN
Description and impact

validateReferral() only checks the referred wallet's current aggregate stake. It does not prove that an eligible stake has matured, that the referral existed before staking, or that the two wallets represent different identities. One operator can control both wallets, receive 1,000 HACK immediately, and repeat the pattern with fresh referrer wallets to bypass the per-address monthly cap.

ES
Recomendación

Registrar el ID del stake elegible y exigir `duration == ONE_MONTH` o superior y `block.timestamp >= startTime + ONE_MONTH`; impedir registrar el referido después del evento de elegibilidad; integrar identidad/KYC o una autorización firmada del backend; aplicar límites por identidad, no solo por wallet; y añadir un `referralId` único e idempotente.

EN
Recommendation

Bind each referral to a unique referralId and a specific stake position. Require the referral to predate the stake, the stake to be active and mature, and enforce identity-level anti-Sybil controls or signed backend attestations.

Foundry evidence / Evidencia Foundry

```
forge test --match-path "test/security/SecurityPoC.t.sol" --match-test
"test_H01_ReferralRewardCanBeClaimedImmediately" -vvvv
```

H-02 La retirada del principal depende del pago de la recompensa y puede quedar bloqueada

High / Alta

Principal withdrawal depends on reward payment and can be blocked

CONTRACTS / CONTRATOS
StakingContract.sol, IncentivesPool.sol

LINES / LÍNEAS
StakingContract.sol:141-175; IncentivesPool.sol:94-110

ES
Descripción e impacto

`unstake()` devuelve el principal y, en la misma transacción, llama a `IncentivesPool.distribute()`. Si el pool no tiene balance contable, no tiene balance real, revocó el rol, fue configurado incorrectamente o está pausado el token, toda la transacción revierte, incluida la devolución del principal. Los usuarios pueden quedar imposibilitados de recuperar sus propios tokens aun después de cumplir el bloqueo. El problema puede afectar a todos los stakers simultáneamente por falta de liquidez o un error de configuración.

EN
Description and impact

unstake() returns principal and calls IncentivesPool.distribute() in the same transaction. Any reward-pool failure reverts the complete transaction, including principal recovery. Users may be unable to recover their own deposited HACK after the lock expires because the reward pool is empty, misconfigured, paused, or missing a role.

ES
Recomendación

Separar el principal de la recompensa. La retirada debe devolver siempre el principal y registrar la recompensa como deuda reclamable (`pendingRewards`) si el pool no puede pagar. Añadir `emergencyWithdrawPrincipal()`, monitoreo de solvencia y pruebas de revocación de roles, pausa y cambio de pool.

EN
Recommendation

Separate principal withdrawal from reward settlement. Always release principal, accrue pendingRewards, and expose an independent claimRewards() path plus an emergency principal-only withdrawal.

Foundry evidence / Evidencia Foundry

```
forge test --match-path "test/security/SecurityPoC.t.sol" --match-test
"test_H02_EmptyRewardPoolBlocksPrincipalWithdrawal" -vvvv
```

H-03 Las vistas académicas pueden inflarse sin límite para apropiarse del pool de educadores

High / Alta

Academic views can be inflated without limit to capture the educator pool

CONTRACTS / CONTRATOS
MembershipSystem.sol

LINES / LÍNEAS
MembershipSystem.sol:249-280; MembershipSystem.sol:288-327

ES
Descripción e impacto

Cualquier miembro académico activo puede llamar `registerContentView()` un número ilimitado de veces, para el mismo educador, contenido y bloque. Un educador también puede adquirir membresía y registrar vistas de su propio contenido. No existe `contentId`, `viewId`, límite por usuario, firma del backend ni protección contra auto-vistas. Un educador puede fabricar la mayoría o totalidad de las vistas y reclamar la porción acumulada de tarifas aportadas por otros miembros. Esto permite extraer el `pendingEducatorPool` sin consumo real de contenido.

EN
Description and impact

Any active academic member can repeatedly call registerContentView() for the same educator. There is no contentId, viewId, replay protection, self-view restriction, or trusted attestation. An educator can manufacture all recorded views and claim most or all of the educator fee pool without genuine content consumption.

ES
Recomendación

Las vistas remunerables deben entrar mediante un rol de registrador/oráculo o firmas EIP-712, con un `viewId` único. Prohibir auto-vistas, limitar una vista remunerable por usuario/contenido/periodo, definir ciclos cerrados y usar snapshots del total de vistas y fondos antes de permitir reclamaciones.

EN
Recommendation

Accept only unique signed view attestations, reject self-views, enforce one payable view per viewer/content/cycle, and distribute against closed-cycle snapshots.

Foundry evidence / Evidencia Foundry

```
forge test --match-path "test/security/SecurityPoC.t.sol" --match-test
"test_H03_EducatorCanSelfGenerateViewsAndDrainPool" -vvvv
```

H-04

Las penalizaciones son voluntarias porque dependen de la aprobación del infractor

High / Alta

Penalties are voluntary because they depend on the offender's allowance

CONTRACTS / CONTRATOS
PenaltySystem.sol, HackTokenERC20.sol

LINES / LÍNEAS
PenaltySystem.sol:128-290;
PenaltySystem.sol:345-383;
HackTokenERC20.sol:76-80

ES
Descripción e impacto

Todas las penalizaciones usan `hackToken.transferFrom(user_, ...)`. El usuario sancionado debe haber otorgado y conservado allowance al contrato. Si no existe allowance o se revoca antes de la ejecución, la penalización revierte. El bloqueo del perfil se actualiza después de la transferencia, por lo que también se revierte. Un infractor puede evitar tanto el pago como el bloqueo simplemente no aprobando el contrato. Esto invalida los mecanismos 7, 9, 14, 25, 26 y 30 como controles coercitivos on-chain.

EN
Description and impact

Penalty execution calls transferFrom(user, ...). The sanctioned user must voluntarily approve and preserve an allowance. Without it, the transfer and the subsequent profile block revert. An offender can avoid both payment and blocking by never approving, or by revoking allowance before enforcement.

ES
Recomendación

Definir explícitamente el modelo de custodia. Opciones: usar saldo previamente escrowed; integrar la sanción en el token mediante una función limitada y auditable que use `BURNER_ROLE`; congelar perfil/saldo primero y registrar deuda pagable; o exigir depósitos colaterales. No depender de una aprobación voluntaria del infractor.

EN
Recommendation

Use a defined custody model: escrowed collateral, a debt-and-freeze workflow, or a narrowly scoped token-level seizure/burn mechanism controlled by a multisig. Do not rely on offender cooperation.

Foundry evidence / Evidencia Foundry

```
forge test --match-path "test/security/SecurityPoC.t.sol" --match-test
"test_H04_PenaltyCanBeAvoidedByWithholdingAllowance" -vvvv
```

H-05

La base de penalización usa saldo movible y la venta masiva se evalúa contra el balance posterior

High / Alta

Penalty calculations use movable balances and mass-sale checks use post-sale state

CONTRACTS / CONTRATOS

PenaltySystem.sol, StakingContract.sol

LINES / LÍNEAS

PenaltySystem.sol:128-219;
PenaltySystem.sol:152-177;
StakingContract.sol:105-175

ES

Descripción e impacto

Las penalizaciones porcentuales leen balanceOf(user) al ejecutar. El usuario puede mover o stakear tokens antes de la sanción. La venta masiva compara los umbrales contra el balance posterior y recibe circulatingSupply del enforcer. El usuario puede reducir la base a cero o quedar debajo del umbral del 1% después de vender, evitando una sanción que habría aplicado con el snapshot previo.

EN

Description and impact

Percentage penalties read balanceOf(user) at enforcement time. A user can transfer or stake tokens first. Mass-sale thresholds are also evaluated using the post-sale balance and enforcer-supplied circulating supply. The penalty base can be reduced to zero or below the 1% eligibility threshold after the event, allowing a sanction to be avoided.

ES

Recomendación

Usar snapshots/attestations del balance previo, monto, supply, bloque y tx hash; registrar una deuda por caseId o cobrar en el settlement de venta.

EN

Recommendation

Enforce against a signed immutable snapshot containing pre-event balance, sale amount, supply, block, tx hash, nonce, and caseId; or collect the penalty inside the settlement path.

Foundry evidence / Evidencia Foundry

```
forge test --match-path "test/business/BusinessLogicPoC.t.sol" --match-test
"test_StakingAllTokensMakesWalletPenaltyBaseZero" -vvvv
forge test --match-path "test/business/BusinessLogicPoC.t.sol" --match-test
"test_MassSaleThresholdUsesPostSaleBalance" -vvvv
```

M-01

`deposit()` incrementa la contabilidad del pool sin comprobar una transferencia real

Medium / Media

deposit() increases pool accounting without proving a token transfer

CONTRACTS / CONTRATOS
IncentivesPool.sol

LINES / LÍNEAS
IncentivesPool.sol:121-130

ES
Descripción e impacto

Un actor con `DEPOSITOR_ROLE` puede llamar `deposit(amount, reason)` sin transferir tokens. La función incrementa `poolBalance` y `totalReceived` de forma ciega y no compara el balance real antes/después. La contabilidad puede quedar por encima del saldo real. Las distribuciones posteriores revierten al agotar el saldo físico, se emiten métricas falsas y se pierde la garantía de solvencia del pool.

EN
Description and impact

An address with DEPOSITOR_ROLE can increase poolBalance and totalReceived without moving HACK into IncentivesPool. Reported solvency can exceed actual assets, causing later distributions to fail and producing misleading accounting events.

ES
Recomendación

Hacer que `deposit()` ejecute `safeTransferFrom()` dentro de la misma función o calcular el delta de balance. Como mínimo, exigir `actualBalance >= poolBalance + amount`. Usar `SafeERC20` y añadir una función controlada para sincronizar donaciones directas.

EN
Recommendation

Perform safeTransferFrom() inside deposit() and account for the measured balance delta. Use SafeERC20 and provide a controlled sync path for direct donations.

Foundry evidence / Evidencia Foundry

```
forge test --match-path "test/security/SecurityPoC.t.sol" --match-test
"testFuzz_M01_DepositInflatesAccountingWithoutTokens" -vvvv
forge test --match-path "test/invariant/IncentivesPoolInvariant.t.sol" --match-test
"testFuzz_ReportedBalanceCanExceedActualAssets" -vvvv
```

M-02 La exención de comisión se activa inmediatamente y puede permanecer con elegibilidad obsoleta

Medium / Media

Fee exemption activates immediately and can remain stale

CONTRACTS / CONTRATOS
StakingContract.sol

LINES / LÍNEAS
StakingContract.sol:184-190; StakingContract.sol:231-242

ES
Descripción e impacto

La exención se habilita por declarar una posición anual sin esperar doce meses. Además, el estado persistente puede continuar después de retirar el stake anual si otras posiciones conservan el agregado requerido. Se reducen ingresos de plataforma y usuarios sin una posición anual madura pueden conservar el beneficio.

EN
Description and impact

A one-year stake is treated as eligible as soon as it is created; twelve months of elapsed time are not required. The persistent boolean can also survive removal of the qualifying position. Users can receive a business benefit before satisfying the documented lock period and may retain it after the qualifying stake is gone.

ES
Recomendación

Derivar la elegibilidad de una posición concreta, activa, con amount >= 100.000 HACK y startTime + 365 days cumplido; evitar booleanos obsoletos.

EN
Recommendation

Bind eligibility to a specific active stake that has actually matured. Prefer derived state over a stale noCommissionActive boolean.

Foundry evidence / Evidencia Foundry

```
forge test --match-path "test/security/SecurityPoC.t.sol" --match-test
"test_M02_NoCommissionCanBeActivatedImmediately" -vvvv
forge test --match-path "test/business/BusinessLogicPoC.t.sol" --match-test
"test_NoCommissionSurvivesAfterQualifyingStakeIsRemoved" -vvvv
```

M-03

El ganador de reputación pierde una ventana de reclamación todavía vigente al cambiar de época

Medium / Media

A reputation winner can lose a still-open claim window at an epoch boundary

CONTRACTS / CONTRATOS
ReputationBunises.sol

LINES / LÍNEAS
ReputationBunises.sol:90-148

ES
Descripción e impacto

`registerWinner()` guarda el bono bajo el mes de registro, pero `claimBonus()` siempre busca el mes calculado en el momento de reclamar. Si el ganador se registra cerca del final de una época de 30 días y reclama después del cambio, la función consulta una entrada vacía aunque no hayan transcurrido los tres días. Ganadores válidos pueden perder el bono por una condición de calendario. El frontend no puede corregirlo porque la función no acepta el mes del bono.

EN
Description and impact

registerWinner() stores the bonus under the registration epoch, while claimBonus() always looks up the current epoch. A valid winner can be denied a reward even though the three-day claim window has not expired.

ES
Recomendación

Aceptar `month_`/`bonusId` en `claimBonus()`, o mantener un `claimableBonusByWinner` que apunte al bono pendiente. Validar la ventana contra `registeredAt`, no contra el mes actual.

EN
Recommendation

Claim by explicit cycleId or bonusId and validate the deadline against registeredAt. Keep a direct pointer to the winner's pending bonus.

Foundry evidence / Evidencia Foundry

```
forge test --match-path "test/security/SecurityPoC.t.sol" --match-test
"test_M03_ReputationClaimBreaksAcrossEpochBoundary" -vvvv
```

M-04 Varios eventos off-chain carecen de identificadores únicos e idempotencia

Medium / Media

Off-chain events lack unique identifiers and idempotency

CONTRACTS / CONTRATOS

EventRewards.sol, EducatorBonuses.sol, RecruiterBonuses.sol

LINES / LÍNEAS

EventRewards.sol:148-166; EventRewards.sol:239-257; EducatorBonuses.sol:260-276; RecruiterBonuses.sol:169-187

ES

Descripción e impacto

Las funciones que registran asistencias, eventos, contrataciones y bonos de contratación solo incrementan contadores o pagan. No reciben un `eventId`/`hiringId` consumible. Un reintento del backend, un mensaje duplicado o un enforcer comprometido puede contabilizar el mismo hecho varias veces. Se pueden alcanzar umbrales con eventos duplicados o pagar repetidamente el mismo hiring, generando inflación y pérdida de fondos del pool. Aunque el enforcer es privilegiado, la idempotencia es necesaria para resistir errores operativos y replays.

EN

Description and impact

Attendance, hosted-event, and hiring functions increment counters or pay rewards without consuming a canonical eventId or hiringId. Backend retries, duplicate messages, or a compromised enforcer can replay the same real-world event and pay it repeatedly.

ES

Recomendación

Añadir IDs canónicos (`bytes32`) por evento/contratación/certificación, almacenar `processed[id]` y rechazar replays. Definir cómo se construye y firma cada ID; usar colas idempotentes y multisig/timelock para pagos excepcionales.

EN

Recommendation

Require a canonical bytes32 evidence ID, store processed[id], verify signed attestations, and reject replays before changing counters or paying rewards.

Foundry evidence / Evidencia Foundry

```
forge test --match-path "test/security/SecurityPoC.t.sol" --match-test
"test_M04_IdenticalHiringCanBeRewardedRepeatedly" -vvvv
```

M-05 Transferir `Ownable` no transfiere la administración de `AccessControl`

Medium / Media

Transferring Ownable ownership does not migrate AccessControl administration

CONTRACTS / CONTRATOS
HackTokenERC20.sol

LINES / LÍNEAS
HackTokenERC20.sol:39-43; HackTokenERC20.sol:87-92

ES
Descripción e impacto

El token combina `Ownable` y `AccessControl`. `transferOwnershipCustom()` solo cambia `owner()`. El deployer conserva `DEFAULT_ADMIN_ROLE`, `MINTER_ROLE`, `BURNER_ROLE` y `PAUSER_ROLE`; el nuevo owner no recibe ninguno automáticamente. Una migración de control puede parecer completada cuando el antiguo operador todavía puede mintear, quemar, pausar y administrar roles. El nuevo owner puede no tener capacidad operativa real.

EN
Description and impact

The token combines Ownable and AccessControl. transferOwnershipCustom() changes owner() only; the deployer keeps DEFAULT_ADMIN_ROLE and operational roles. A control migration can appear complete while the former operator can still mint, burn, pause, and grant roles. The new owner may have no operational authority.

ES
Recomendación

Usar un único modelo de autoridad o implementar una migración atómica/two-step de roles. Preferir `AccessControlDefaultAdminRules` con retraso, multisig y renuncia explícita del administrador anterior. Documentar que ownership no controla los roles si se conserva ambos modelos.

EN
Recommendation

Use one authority model or an explicit two-step role migration. Prefer delayed default-admin transfer to a multisig and require the former admin to renounce all roles.

Foundry evidence / Evidencia Foundry

```
forge test --match-path "test/security/SecurityPoC.t.sol" --match-test
"test_M05_OwnershipTransferDoesNotMoveAccessControlAdmin" -vvvv
```

M-06 Los bonos de recruiter no verifican actividad real ni consistencia de registro/KYC

Medium / Media

Recruiter rewards do not prove real activity or registration/KYC consistency

CONTRACTS / CONTRATOS
RecruiterBonuses.sol

LINES / LÍNEAS
RecruiterBonuses.sol:116-159;
RecruiterBonuses.sol:169-220;
RecruiterBonuses.sol:231-261

ES
Descripción e impacto

El bono de “7 active days” solo comprueba tiempo transcurrido desde el registro; no registra actividad. Las contrataciones se pueden registrar para direcciones no registradas y el bono KYC puede reclamarse sin exigir `isRegistered`. `verifyKyc()` también puede repetirse hasta que el bono sea reclamado. La implementación no garantiza las condiciones descritas y depende completamente de disciplina off-chain. Errores del enforcer pueden pagar wallets no elegibles o sin actividad.

EN
Description and impact

The seven-day registration reward checks elapsed time, not activity. Hiring and KYC flows do not consistently require registration, and KYC verification can be repeated before claim. Wallets that do not satisfy the documented business conditions may receive large rewards due to enforcer mistakes or weak off-chain discipline.

ES
Recomendación

Definir actividad verificable (`lastActiveAt`, días únicos o attestations), exigir registro/KYC en los flujos correspondientes e incorporar IDs de contratación. Si todo es off-chain, consolidar la verificación en una autorización firmada con nonce y fecha de expiración.

EN
Recommendation

Track verifiable activity, require registration and KYC in every relevant flow, use unique evidence IDs, and authorize claims through nonce-protected signed attestations.

Validation status / Estado: manual finding; implement the acceptance test listed in the Developer Security Handbook before closure.

L-01 Se ignoran valores de retorno de transferencias ERC20 en membresías y penalizaciones

Low / Baja

ERC-20 transfer return values are ignored in memberships and penalties

CONTRACTS / CONTRATOS
MembershipSystem.sol, PenaltySystem.sol

LINES / LÍNEAS
MembershipSystem.sol:159-164;
MembershipSystem.sol:195-199;
MembershipSystem.sol:224-226;
MembershipSystem.sol:266;
PenaltySystem.sol:250-253;
PenaltySystem.sol:358-364

ES
Descripción e impacto

Varias llamadas `transfer()` no comprueban el booleano devuelto. Con el `HackToken` incluido, OpenZeppelin devuelve `true` o revierte, por lo que el riesgo es latente; sin embargo, los constructores aceptan cualquier dirección ERC20 y el código pretende ser genérico. Con un token no estándar o una dirección incorrecta, el sistema puede continuar, modificar estado o notificar depósitos aunque la transferencia haya devuelto `false`.

EN
Description and impact

Several transfer() calls do not validate the returned boolean. The bundled OpenZeppelin token reverts or returns true, but constructors accept arbitrary ERC-20 addresses. With a non-standard token, state may be updated even when a transfer silently returns false.

ES
Recomendación

Usar `SafeERC20.safeTransfer` y `safeTransferFrom` en todos los contratos. Validar `code.length` en constructores y fijar/verificar la dirección exacta del token en despliegue.

EN
Recommendation

Use SafeERC20.safeTransfer/safeTransferFrom consistently and validate that configured token addresses contain code and match the intended HACK deployment.

Validation status / Estado: manual finding; implement the acceptance test listed in the Developer Security Handbook before closure.

L-02 La validación de índice de stake ocurre después de acceder al array

Low / Baja

Stake index validation occurs after the array is accessed

CONTRACTS / CONTRATOS
StakingContract.sol

LINES / LÍNEAS
StakingContract.sol:141-146

ES
Descripción e impacto

`Stake storage userStake = userStakes[msg.sender][stakeIndex_]` se ejecuta antes de comprobar `stakeIndex_ >= length`. Un índice inválido produce un panic de array y hace inalcanzable el error `StakeNotFound`. No se pierden fondos, pero se rompe la semántica de errores, complica integraciones y evidencia un orden incorrecto de validación.

EN
Description and impact

unstake() reads userStakes[msg.sender][stakeIndex] before checking whether the index is within bounds. Invalid input triggers a Solidity panic rather than the documented StakeNotFound custom error, complicating integration and monitoring.

ES
Recomendación

Mover la comprobación de longitud antes de obtener la referencia storage.

EN
Recommendation

Check stakeIndex < userStakes[msg.sender].length before taking the storage reference.

Foundry evidence / Evidencia Foundry

```
forge test --match-path "test/security/SecurityPoC.t.sol" --match-test
"test_L02_InvalidStakeIndexPanicsBeforeCustomError" -vvvv
```

L-03

El estado de membresía avanzada permanece activo tras expirar y permite penalizar cancelaciones vencidas

Low / Baja

Expired advanced memberships remain flagged active and can be charged a cancellation penalty

CONTRACTS / CONTRATOS
MembershipSystem.sol

LINES / LÍNEAS
MembershipSystem.sol:143-145;
MembershipSystem.sol:182-204;
MembershipSystem.sol:211-238

ES
Descripción e impacto

`active` no se actualiza automáticamente al expirar. `activateAdvancedMembership()` rechaza al usuario porque `active == true`, mientras `cancelAdvancedMembership()` acepta la membresía expirada y cobra una penalización. La única ruta razonable es `renewAdvancedMembership()`. La interfaz puede ofrecer acciones inconsistentes y cobrar 1.000 HACK por cancelar algo que ya terminó.

EN
Description and impact

The stored active flag is not synchronized with expiresAt. Activation, cancellation, and view functions use different definitions of membership state. A user may be unable to activate a new membership and may be charged 1,000 HACK to cancel an already expired membership.

ES
Recomendación

Usar una única fuente de verdad (`expiresAt > block.timestamp`), permitir reactivación si expiró y exigir `expiresAt > block.timestamp` para penalizar una cancelación temprana.

EN
Recommendation

Use one _isActive() predicate, allow activation after expiry, and charge cancellation only while expiresAt is still in the future.

Validation status / Estado: manual finding; implement the acceptance test listed in the Developer Security Handbook before closure.

L-04 Bucles y lotes no acotados pueden exceder el límite de gas

Low / Baja

Unbounded loops and batches can exceed the block gas limit

CONTRACTS / CONTRATOS
StakingContract.sol, TalentBonuses.sol

LINES / LÍNEAS
StakingContract.sol:231-242; TalentBonuses.sol:192-220

ES
Descripción e impacto

La elegibilidad sin comisión recorre todas las posiciones del usuario y la distribución de proyectos hace múltiples transferencias en un loop de longitud arbitraria. Usuarios con muchas posiciones pueden auto-bloquear la activación por gas; lotes grandes de distribución pueden ser imposibles de ejecutar.

EN
Description and impact

Fee-exemption eligibility iterates over all user stakes and project distribution loops over an arbitrary talent list. Users with many positions may be unable to activate benefits, and large project payouts may become permanently unexecutable.

ES
Recomendación

Mantener agregados/indexes de stakes elegibles y limitar el tamaño de batch. Permitir distribución por páginas o modelo pull-payment.

EN
Recommendation

Maintain indexed eligibility aggregates, cap batch sizes, paginate operations, or use a pull-payment model where each beneficiary claims independently.

Validation status / Estado: manual finding; implement the acceptance test listed in the Developer Security Handbook before closure.

L-05

El patrocinador de un proyecto puede sobrescribirse y no existe ruta de reembolso

Low / Baja

Project sponsor attribution can be overwritten and funds have no refund path

CONTRACTS / CONTRATOS
TalentBonuses.sol

LINES / LÍNEAS
TalentBonuses.sol:167-220

ES
Descripción e impacto

Cualquier dirección puede financiar el mismo `projectId`; `projectSponsor[projectId]` se sobrescribe con el último financiador mientras los montos se acumulan. No se valida `projectId != 0`, no se restringe el rol del sponsor y no existe cancelación/reembolso si el enforcer no distribuye. Se pierde atribución, los fondos pueden permanecer bloqueados indefinidamente y la implementación no respeta la descripción “Educator or Recruiter”.

EN
Description and impact

Multiple wallets can fund the same projectId, but projectSponsor stores only the latest sponsor while balances accumulate. Zero IDs and unrestricted sponsors are accepted. Attribution is lost and funds can remain locked indefinitely if distribution never occurs.

ES
Recomendación

Modelar aportes por sponsor, impedir sobrescritura o soportar múltiples sponsors explícitamente; validar ID y rol; añadir deadline, cierre y reembolso de saldo no distribuido.

EN
Recommendation

Track contributions per sponsor, validate projectId and sponsor roles, define a funding deadline, and allow refund of undistributed balances after cancellation or expiry.

Foundry evidence / Evidencia Foundry

```
forge test --match-path "test/business/BusinessLogicPoC.t.sol" --match-test
"test_ProjectFundingAcceptsZeroProjectIdAndUnrestrictedWallet" -vvvv
```

L-06 La pausa de emergencia no es granular y puede bloquear retiros

Low / Baja

Emergency pausing is not granular and can block withdrawals

CONTRACTS / CONTRATOS

HackTokenERC20.sol, StakingContract.sol, MembershipSystem.sol, IncentivesPool.sol

LINES / LÍNEAS

HackTokenERC20.sol:99-114; StakingContract.sol:105-175; MembershipSystem.sol:112-238; IncentivesPool.sol:75-110

ES

Descripción e impacto

HackToken aplica una pausa global a toda operación ERC-20 mediante `_update()`, pero los módulos que reciben fondos no tienen una pausa de entradas independiente. Pausar el token evita nuevos depósitos y también impide devolver el principal desde staking. La respuesta a incidentes obliga a escoger entre dejar módulos vulnerables activos o congelar también salidas legítimas. Esto puede agravar el bloqueo de principal descrito en H-02.

EN

Description and impact

HackToken pauses every ERC-20 transfer globally, while deposit-taking modules do not expose independent entrance pauses. Incident response must choose between leaving vulnerable entrances open or also freezing legitimate principal withdrawals.

ES

Recomendación

Añadir Pausable por módulo/flujo: `whenNotPaused` en stake, activaciones, renovaciones, financiaciones y depósitos; mantener retiros de principal y cancelaciones seguras disponibles. Operar EMERGENCY_ROLE mediante multisig, eventos y runbook.

EN

Recommendation

Add module-level pause controls to new deposits, memberships, funding, and reward registrations while keeping principal withdrawals and safe exits available.

Validation status / Estado: manual finding; implement the acceptance test listed in the Developer Security Handbook before closure.

I-01

“Mes” se implementa como épocas globales de 30 días y puede borrar calificaciones al cambio

Informational / Informativa

Thirty-day global epochs do not match calendar months and can erase earned progress

CONTRACTS / CONTRATOS

ReferralSystem.sol, EventRewards.sol, RecruiterBonuses.sol, TalentBonuses.sol, ReputationBunises.sol

LINES / LÍNEAS

Múltiples usos de block.timestamp / 30 days

ES

Descripción e impacto

Las épocas no corresponden a meses calendario y los contadores se reinician al primer llamado en una época nueva. En EventRewards y RecruiterBonuses no existe periodo de gracia para reclamar logros del periodo anterior. La experiencia puede divergir de la política de negocio y usuarios que alcanzaron un umbral al final del periodo pueden perderlo al cambiar la época.

EN

Description and impact

Several modules compute month as block.timestamp / 30 days and reset a single current-period struct. This may diverge from calendar-month rules and remove late-period achievements.

ES

Recomendación

Definir explícitamente periodos, IDs de ciclo y ventanas de reclamación. Mantener históricos por `cycleId` en vez de sobrescribir un único struct.

EN

Recommendation

Introduce explicit cycleId values, historical records, and grace periods for claims.

Validation status / Estado: manual finding; implement the acceptance test listed in the Developer Security Handbook before closure.

I-02

Las recompensas asignadas no están reservadas y dependen de liquidez/roles en el momento del claim

Informational / Informativa

Eligible rewards are not reserved and remain dependent on pool liquidity and roles

CONTRACTS / CONTRATOS

Todos los módulos de recompensas, IncentivesPool.sol

LINES / LÍNEAS

Llamadas a IncentivesPool.distribute()

ES

Descripción e impacto

Los módulos registran elegibilidad pero no reservan fondos. Cualquier distribuidor puede consumir el pool antes de que otro usuario reclame. En la mayoría de módulos el claim puede reintentarse porque el estado revierte; en staking la consecuencia escala a H-02. Riesgo de liveness, carreras económicas y obligaciones sin respaldo.

EN

Description and impact

Modules record eligibility without reserving backed assets. Other distributors can consume the pool before a claim is made.

ES

Recomendación

Implementar presupuestos por módulo/ciclo, reservas contables respaldadas por balance real y monitoreo de obligaciones frente a liquidez.

EN

Recommendation

Implement module/cycle budgets, backed reservations, and solvency monitoring.

Validation status / Estado: manual finding; implement the acceptance test listed in the Developer Security Handbook before closure.

I-03

Faltan bloqueo de dependencias, pruebas originales, scripts de despliegue y configuración de roles

Informational / Informativa

The production repository must retain the reproducible Foundry environment and role configuration

CONTRACTS / CONTRATOS
Repositorio completo

LINES / LÍNEAS
README.md y estructura del repositorio

ES
Descripción e impacto

El repositorio de producción debe conservar el entorno Foundry reproducible, las dependencias fijadas, las pruebas, los scripts de despliegue y la automatización idempotente de roles. Estos controles no deben quedar únicamente como artefactos de auditoría. Compilaciones futuras pueden cambiar, un despliegue puede omitir roles críticos y no existe evidencia reproducible previa a esta auditoría.

EN
Description and impact

The final audit package now contains a Foundry-only environment, tests, scripts, and pinned dependencies. These controls must be adopted in the production repository rather than treated as audit-only artifacts.

ES
Recomendación

Versionar dependencias, incorporar el entorno entregado, scripts idempotentes de despliegue/configuración y CI que compile, pruebe, ejecute Slither y verifique matriz de roles.

EN
Recommendation

Keep foundry.toml, vendored/pinned dependencies, CI, and idempotent deployment/role scripts under version control.

Validation status / Estado: manual finding; implement the acceptance test listed in the Developer Security Handbook before closure.

I-04

Problemas de calidad y observabilidad reducen mantenibilidad

Informational / Informativa

Code quality and observability issues reduce maintainability

CONTRACTS / CONTRATOS

ReputationBunises.sol, MembershipSystem.sol, PenaltySystem.sol, varios

LINES / LÍNEAS

ReputationBunises.sol (nombre de archivo); MembershipSystem.sol:69-72; PenaltySystem.sol:96

ES

Descripción e impacto

El archivo `ReputationBunises.sol` está mal escrito; `pendingRewards` se incrementa pero nunca se consume; existen errores/eventos no usados (`PenaltyPaid`, `ProfileAlreadyBlocked`, etc.); setters críticos no emiten eventos; y varios comentarios no coinciden con la lógica. Aumenta el riesgo de integración, monitoreo incorrecto y futuras modificaciones defectuosas.

EN

Description and impact

Misspelled filenames, dead state, unused errors/events, missing configuration events, and stale comments increase integration and monitoring risk.

ES

Recomendación

Corregir nombres, eliminar estado muerto, emitir eventos de configuración y alinear NatSpec con reglas verificables.

EN

Recommendation

Remove dead code, correct naming, emit configuration events, and align comments with executable behavior.

Validation status / Estado: manual finding; implement the acceptance test listed in the Developer Security Handbook before closure.

I-05

Mappings públicos y getters explícitos duplican la superficie ABI

Informational / Informativa

Public mappings and explicit getters duplicate the ABI surface

CONTRACTS / CONTRATOS

EducatorBonuses.sol, EventRewards.sol, PenaltySystem.sol, RecruiterBonuses.sol, ReferralSystem.sol, StakingContract.sol, TalentBonuses.sol

LINES / LÍNEAS

EducatorBonuses.sol:43-66; EventRewards.sol:64-73; PenaltySystem.sol:71-77; RecruiterBonuses.sol:58-71; ReferralSystem.sol:46-52; StakingContract.sol:53-59; TalentBonuses.sol:43-55

ES

Descripción e impacto

Se identificaron al menos 16 accesos escalares donde un mapping `public` genera un getter automático y existe además una función que devuelve exactamente el mismo valor. No es una explotación directa, pero aumenta bytecode, entradas ABI, costo de mantenimiento y acoplamiento del almacenamiento con frontend/indexadores.

EN

Description and impact

At least sixteen scalar values are exposed both through an automatic public-mapping getter and a wrapper function.

ES

Recomendación

Conservar una sola ruta. Para datos simples estables, mapping público sin wrapper; para abstracción, mapping privado y getter explícito. Coordinar cualquier cambio de ABI.

EN

Recommendation

Expose one stable access path: public mapping for simple stable storage, or private mapping plus an explicit abstraction getter.

Validation status / Estado: manual finding; implement the acceptance test listed in the Developer Security Handbook before closure.

I-06

NatSpec incompleto y parcialmente desalineado con la lógica

Informational / Informativa

NatSpec is incomplete and partially inconsistent with behavior

CONTRACTS / CONTRATOS

Todos los contratos e interfaces

LINES / LÍNEAS

HackTokenERC20.sol:17-104; StakingContract.sol:181; Interfaces internas sin NatSpec completo

ES

Descripción e impacto

La mayoría de funciones tiene comentarios, pero faltan tags `@param`/`@return`, documentación de errores y trust assumptions; algunos comentarios describen historial de cambios o requisitos distintos al comportamiento real. Aumenta el riesgo de integración incorrecta, revisión defectuosa y decisiones de usuario basadas en documentación inexacta.

EN

Description and impact

Public ABI documentation does not consistently describe parameters, returns, roles, units, trust assumptions, pause behavior, or actual eligibility rules.

ES

Recomendación

Documentar toda la ABI con notice/dev/param/return, unidades, roles, pausas, invariantes, eventos y errores. Generar userdoc/devdoc en CI y fallar ante cobertura o comentarios obsoletos.

EN

Recommendation

Document the full ABI and generate userdoc/devdoc in CI to detect missing or stale documentation.

Validation status / Estado: manual finding; implement the acceptance test listed in the Developer Security Handbook before closure.

I-07 Modernización condicional a ReentrancyGuardTransient

Informational / Informativa

Conditional modernization to ReentrancyGuardTransient

CONTRACTS / CONTRATOS

EducatorBonuses.sol, EventRewards.sol, MembershipSystem.sol, PenaltySystem.sol, RecruiterBonuses.sol, ReferralSystem.sol, ReputationBunises.sol, StakingContract.sol, TalentBonuses.sol

LINES / LÍNEAS

Imports/herencia de ReentrancyGuard en nueve contratos

ES

Descripción e impacto

El commit usa OpenZeppelin 5.0.2 con ReentrancyGuard. OpenZeppelin 5.x ofrece ReentrancyGuardTransient para redes EIP-1153. Se compiló una variante aislada con OZ 5.6.1, solc 0.8.24 y evmVersion Cancun. No corrige una vulnerabilidad demostrada; es una mejora de compatibilidad futura y potencial gas. Desplegarla en una red sin EIP-1153 haría el bytecode incompatible.

EN

Description and impact

Transient-storage reentrancy guards can reduce storage overhead on compatible EVM targets, but this is not a remediation for a demonstrated exploit and is unsafe on unsupported chains.

ES

Recomendación

Migrar solo tras confirmar red, hard fork y toolchain; fijar versión, usar perfil Cancun, ejecutar suite completa y fork/testnet. Mantener perfiles separados para multichain.

EN

Recommendation

Adopt only after confirming chain support, Cancun-compatible toolchain settings, full regression tests, and deployment verification.

Validation status / Estado: manual finding; implement the acceptance test listed in the Developer Security Handbook before closure.

Remediation roadmap / Plan de remediación

Phase / Fase	Required work / Trabajo requerido	Exit gate / Criterio de salida
0 - Freeze	Do not deploy or fund production contracts. Protect admin keys and define multisig roles.	No real user funds at risk.
1 - Critical design	Resolve H-01 through H-05: referral maturity, principal/ reward separation, view attestations, enforceable penalties, immutable snapshots.	All High closure tests pass.
2 - Accounting and authority	Resolve M-01 through M-06 and add canonical evidence IDs.	All Medium tests and invariants pass.
3 - Operational safety	SafeERC20, index order, state consistency, bounded batches, project refunds, granular emergency stop.	All Low tests pass.
4 - Engineering quality	Cycles, reserves, CI, event observability, ABI cleanup, NatSpec, conditional transient guard evaluation.	Documentation and CI gates complete.
5 - Re-audit	Diff review, full Foundry regression, fuzz/invariant expansion, testnet rehearsal, role and bytecode verification.	Independent sign-off before production.

ES

Dictamen final

NO APTO PARA PRODUCCIÓN con fondos reales en el estado auditado.

EN

Final assessment

NOT READY FOR PRODUCTION with real funds in the audited state.